

ESTUDO DE CASO: COMO UM ATAQUE DE ENGENHARIA SOCIAL AFETOU HOTÉIS E CASSINOS EM LAS VEGAS

PARTE 1 – IDENTIFICAÇÃO TÉCNICA

Ameaça

- **Qual era a principal ameaça?** Um grupo de cibercriminosos que utilizou táticas de engenharia social contra a equipe da empresa.
- **Que tipo de ataque ocorreu?** Ataque de engenharia social

Exemplo do que se trata engenharia social:



Vulnerabilidade

- **Que vulnerabilidade os invasores exploraram?** Ele explorou informações pessoais públicas dos funcionários, além deles se passarem como funcionários para conseguir acesso através do setor de suporte.
- **Houve erro humano?** Sim, pelo fato de informações públicas poderem ser exploradas tão facilmente nos sistemas, e a falta de conferência em relação as credenciais de suporte.

Risco

- **Qual foi o impacto do incidente nas operações da empresa?** Os impactos foram dificuldades com o uso de chaves digitais por parte dos clientes para ter acesso aos quartos, além de problemas relacionados a reservas, pagamentos e determinados serviços internos do hotel. Além desse transtorno aos clientes,

também causou uma macha para imagem do hotel, mostrando sua vulnerabilidade.

Controles de Segurança

- ***Quais controles poderiam ter ajudado a reduzir o impacto?*** Primeiramente, eles poderiam ter utilizado identificação de dois fatores para prevenir os ajustes, além de ter políticas de alteração de senhas a cada 90 dias e criar procedimentos interno no suporte técnico para evitar a entrada de pessoas não autorizadas, e a falsa “identidade”.

- ***Como a autenticação multifator (MFA) poderia ter contribuído para a proteção dos sistemas?*** Ela poderia ter contribuído porque ela atua exigindo não apenas algo que o usuário sabe, que é a senha, mas também tem um aplicativo, um token que “libera” o acesso do usuário autorizado. O MFA teria servido como uma barreira para impedir a instrução inicial, porque mesmo os criminosos tendo acesso a senha, eles seriam barrados na identificação de dois fatores.

Exemplo de MFA:



Monitoramento

- ***Que tipos de alertas poderiam ser identificados por um SOC (Centro de Operações de Segurança) nesse caso?*** Um SOC conseguiria identificar que havia sido realizado logins em horários diferentes do habitual, além de se utilizar da localização (GPS) para conferir de onde essas pessoas estavam acessando.

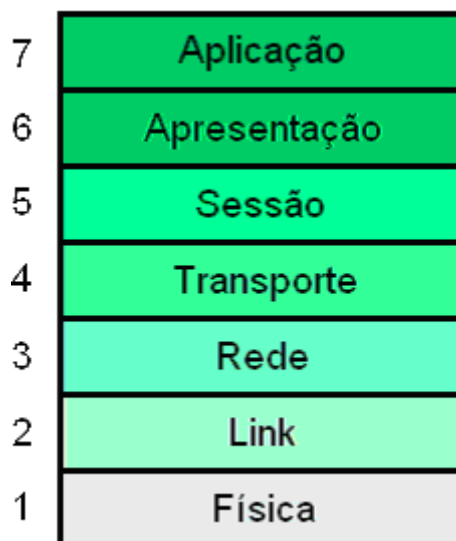
PARTE 2 – RELAÇÃO COM OS TÓPICOS DO MÓDULO FUNDAMENTOS DE REDES

• **Quais sistemas ou serviços dependiam da rede para funcionar?** Os serviços afetados foram: chaves digitais de acesso ao quarto, sistema de reservas e pagamentos, máquina caça-níqueis, caixas eletrônicos, serviços internos dos hotéis e nas plataformas utilizadas pelos funcionários.

Modelo OSI

• **Quais camadas do Modelo OSI estavam envolvidas no incidente?** As camadas envolvidas foram a 7 (aplicação), uma vez, que os softwares de reservas, interfaces de pagamento, sistemas de caça-níqueis e plataformas de funcionários não funcionaram. As camadas 3 e 4 (Rede e Transporte), que foram envolvidas na movimentação dos invasores pela rede interna para explicara diferentes recursos tecnológicos.

Camadas:



AAA (Autenticação, Autorização e Auditoria)

- **Qual a relação entre o modelo AAA, a autenticação dos usuários e o controle de acesso aos sistemas?**

Autentificação	Os invasores enganaram o suporte técnico e gerencialmente de acessos para obter credenciais válidas, burlando a verificação de quem eles realmente eram
Autorização	Com a autenticação realizada, o sistema concedeu aos invasores os acessos para entrar nos sistemas internos e utilizar os recursos.
Auditoria	A auditoria foi o que permitiu descobrir o ataque, com os registros de logs a equipe conseguiu notar o comportamento atípico e em locais diferentes.

IDS/IPS

- **Quais atividades suspeitas poderiam ser detectadas por sistemas IDS ou IPS?** Esses tipos de sistemas analisam o tráfego da rede, eles poderiam identificar a “exploração dos sistemas internos” quando os criminosos acessaram e poderia bloquear esse tráfego anormal.

SOC e Monitoramento

- **O que um analista júnior de segurança poderia fazer em uma situação como essa?** Primeiramente ele verificaria o painel de monitoramento, a função dele seria cruzar alertas de logins em locais estranho e comportamentos atípicos. Ao confirmar suas suspeitas, ele iria documentar e iria acionar a equipe sênior para dar andamento as ações necessárias.

ATIVIDADE FINAL

Crie um mini relatório em PDF GitHub respondendo às seguintes questões:

- **O que aconteceu?** Em setembro de 2023, a MGM Resorts Internacional, sofreu um ataque cibernético, no qual afetou as chaves digitais para acessar os quartos, além de problemas em reservas, pagamentos e serviços internos do hotel.
- **Qual vulnerabilidade foi explorada?** Foi explorada falhas técnicas (o sistema não possuía sistema de MFA, o que facilitou a entrada dos criminosos) e humanas (pelo fato de informações públicas poderem ser exploradas tão facilmente nos sistemas, e a falta de conferência em relação as credenciais de suporte).

• ***Qual foi o impacto do incidente?*** Os impactos foram: manchar a reputação do hotel (demonstrando graves falhas de segurança), prejudicar a experiência dos clientes (procedimentos internos que foram atrapalhados, além do acesso aos quartos) e financeiros (dificuldade em reservas, pagamentos e funcionamentos de máquinas de caça-níquel).

• ***Quais controles de segurança estavam ausentes ou poderiam ter sido aprimorados?*** Os controles que estavam ausentes foram a falta de aplicativos de autenticação de dois fatores, falta de procedimentos para confirmar a identificação dos funcionários que tem acesso ao suporte técnico.

• ***Quais foram os principais aprendizados obtidos com este caso?*** O maior aprendizado é entender a vulnerabilidade dos sistemas, e que mesmo se tratando de um hotel grande e famosos, pode demonstrar falhas e a necessidade de melhorar os processos e treinamentos internos. Não devemos minimizar a questão da segurança, porque é pago um preço alto.